



Novix

Your family's health records — organized, explained, and reachable in an emergency.

Laravel 11.54

PHP 8.2+

MySQL 8/9

Tailwind CSS

Alpine.js

Gemini + Groq AI

COMPLETE PROJECT DOCUMENTATION

Architecture, Features & Build Notes

Generated July 18, 2026

Table of Contents

01  About

02  Features

03  Tech Stack

04  Architecture & Pipelines

05  Database Schema

06  Project Structure

07  Application Routes

08  Getting Started

09  Security & Privacy

10  Roadmap

11  Contributing

12  License

Novix is a secure, family-oriented health record manager. It gives a household a single place to store, understand, and act on every family member's medical history — lab reports, prescriptions, medications, vitals, allergies, and emergency information — instead of scattered paper files and phone photos.

Every family member is represented as their own record with two possible modes: a **linked** member who has their own login (the account owner, or anyone they've invited who accepted), or a **dependent** member with no login of their own (a child, an elderly parent) whose records the primary account manages directly. Two independent adult accounts can also link to each other and share access on their own terms — never a one-way street.

⚠️ **Not a medical device.** Novix organizes, extracts, and explains records for convenience. Every AI-generated summary carries a disclaimer and is never presented as a diagnosis. It does not replace a qualified doctor.

✨ Features

Onboarding & Identity

FEATURE	DESCRIPTION
 5-Step Animated Registration Wizard	Session-backed multi-step signup (survives a page refresh) — account basics with live email availability + password strength, live selfie capture via the browser camera, cascading country/state/city address, an animated semi-circular BMI gauge with allergy/medicine tags, and a final review-and-confirm step with required consent capture. Nothing touches the database until the final step.
 Google OAuth + Password Auth	Sign in with Google or email/password. A brand-new Google identity is never turned into a database row until the wizard's final step completes — an abandoned signup leaves no account behind either way.
 Live Camera Capture	<code>getUserMedia</code> -based capture with a face-guide overlay, square crop, client-side JPEG compression, and a file-upload fallback for devices without a camera.
 Cascading Location Picker	Real country → state → city data (India defaulted, full global dataset), lazy-loaded on demand so it never bloats other pages.

Family & Dashboard

FEATURE	DESCRIPTION
 Family Dashboard	Hero card with photo/blood group/health ID, live BMI trend, recent reports with AI summaries, today's medications, quick-action tiles, and a family-member switcher.

FEATURE	DESCRIPTION
 Family Management	Invite an independent adult by email (they keep their own login and choose exactly what to share back — full, reports-only, or summary-only) or add a dependent with no login of their own. Archive/restore respects every <code>RESTRICT</code> -guarded medical table. An in-app popup surfaces pending invitations the moment you log in.
 Reciprocal Sharing	If someone you invite already has their own Novix account, inviting them creates a two-way grant instead of colliding with their existing profile — both sides see the connection and can revoke it independently from their own "Shared With" list.
 Tabbed Profile Editor	Independently-saving tabs — Basic Info, Photo, Address, Health, Emergency Contact, Account Security — each with inline AJAX feedback, no full-page reloads. Reused for editing dependents and for full-access linked members.
 BMI History, Not Overwrites	Editing height/weight always inserts a new <code>bmi_logs</code> row, preserving trend history instead of destroying it.
 Dark Mode	Toggle persisted server-side per user, not just in browser storage — follows you across devices.
 First-Run Checklist	A dismissible dashboard card guiding a brand-new account through its first three real actions — add a family member, upload a report, try the assistant — computed from actual data, not a hardcoded flag.

Medications & Vaccinations

FEATURE	DESCRIPTION
 Medication Management	Full CRUD for dosage, frequency, multiple reminder times per day, a start/end date range, and a per-medication reminder toggle.
 Tap-to-Mark Dose Tracking	Each scheduled dose shows as a pill on the dashboard — pending, taken, or missed — that toggles with a single tap, no page reload. A daily job generates the day's pending dose slots; a 15-minute sweep ages any slot nobody acted on into "missed" after a grace period.
 Real Email Reminders	An actual email goes out around each scheduled dose time (if reminders are on for that medication), and once a day for any vaccination due within a week or already overdue — not just a UI badge nobody sees.
 Vaccination Tracking	Dose number, date administered, next-due date, and location, with overdue/due-soon badges surfaced on both the dedicated page and the dashboard.

Reports, OCR & AI

FEATURE	DESCRIPTION
 Batch Report Upload	Drag-and-drop, camera capture, or file picker for PDF/JPG/PNG — multiple files at once, each with its own thumbnail, upload-progress bar, and metadata form.
 Auto-Detect on Upload	The instant a file is selected, it's OCR'd in the background and the report type, date, hospital, and doctor fields are pre-filled from local heuristics (keyword-scored type classification, date-format parsing, matching against the family's own upload history) — no AI cost. Manually-edited fields are never overwritten. The extracted text is cached by file hash so the real upload moments later reuses it instead of running OCR twice.

FEATURE	DESCRIPTION
 Duplicate Detection	Re-uploading the exact same file (matched by content hash, not filename) warns you with a link to the existing report and an explicit "upload anyway" override, instead of silently creating a copy.
 Fast, Parallel OCR Pipeline	A queued job runs every upload through Tesseract — pages of a multi-page PDF are OCR'd concurrently (capped batches) instead of one at a time, cutting multi-page processing time by roughly half to two-thirds. PDFs are rasterized via Imagick/Ghostscript; photos get grayscale/contrast/deskew/despeckle preprocessing, since a real phone photo of a prescription is rarely flat and well-lit. A page that reads as garbled automatically retries at 90°/180°/270° rotation — a common fix for sideways phone photos — before giving up.
 Editable Extracted Text	The OCR result is shown in a collapsible panel the user can correct by hand — a human correction always overwrites the machine's guess.
 Search & Filter Reports	Full-text search across every report's OCR text, AI summary, filename, hospital, and doctor, plus type and date-range filters on the Reports list.
 Automatic Short AI Summary	The moment OCR succeeds, a 2–3 sentence AI summary is generated automatically — deliberately brief and always disclaimer-stamped.
 On-Demand Detailed Explanation	A "Get detailed explanation" button calls the AI again for a fuller, plain-language breakdown with doctor-discussion questions — never auto-run, so it never spends AI usage without the user asking. Every explanation is kept in a permanent history, not just the latest. A "Try summary again" retry path exists for the rare automatic summary that fails outright.
 Cached Translation	Switch the summary between English/Hindi/Gujarati — each language is translated once and cached in <code>ai_responses</code> ; flipping back and forth never re-calls the API.
 Pattern-Matched Vitals	Blood pressure, blood sugar, HbA1c, cholesterol, and hemoglobin are parsed straight out of the OCR text into <code>health_metrics</code> — no AI call needed, feeds the timeline's trend view for free.
 AI Assistant Chat	A per-family-member chat that answers questions using that person's actual records (reports, medications, vaccinations, vitals) or explains how to use Novix itself — whichever the question calls for — via a single context-aware prompt. Conversation history persists and folds into later turns.
 Multi-Provider AI Fallback	Every AI feature routes through up to three Gemini API keys and then Groq as a last resort, tried in order — a key hitting its free-tier limit, or a transient provider outage, no longer takes AI features down. A credential that just failed is skipped for a cooldown window rather than retried on every call.

Emergency Access & Sharing

FEATURE	DESCRIPTION
 Public Emergency Card	A no-login page any first responder can open by scanning a real QR code — photo, age (computed from DOB), blood group front-and-center, allergies flagged red-first by severity, active conditions/medications, tap-to-call emergency contact, family doctor. Deactivating it hides everything within seconds.
 Print-Ready Card PDFs	A wallet/ID-card-sized PDF and a full-page PDF, both with the same real, scannable QR code embedded — genuinely meant to be printed and carried, not a mockup.
 Multi-Language Card	English/Hindi/Gujarati toggle on the public card — reads from a static label dictionary, never calls the AI API live.

FEATURE	DESCRIPTION
 Reissue & Instant Deactivate	Lost the card? Reissue generates a fresh card number and QR while keeping the old one on record as issuance history; deactivate flips it off instantly without needing a reissue.
 Time-Boxed Report Sharing	Share one report or a family member's full history via a link that always expires (24h/48h/7 days/custom — never "forever"), optional 4-digit PIN (hash stored, never the plain code), and optional one-time-view that auto-revokes itself right after the first open.
 Real Share QR + Native Share	A scannable QR for the share link, one-tap copy, and the Web Share API for WhatsApp/Email where the browser supports it.
 Doctor-Ready Share PDF	The public share page's PDF export includes only minimal identity (name/age/blood group — never address or emergency contact), the original report image, OCR text, and the AI summary/explanation — laid out to actually hand to a doctor.
 Share History, Never a Black Box	Every link ever created for a family member, with live status (active/expired/revoked/viewed), view count, last-viewed time, and one-click revoke.

Timeline & Compliance

FEATURE	DESCRIPTION
 Health Timeline	Reports, medications, vaccinations, and vitals merged into one chronological feed, grouped by year → month with older years collapsed by default. Filter by category or date range, full-text search across every report's OCR text and AI summary, and inline accordion previews.
 Compare Over Time	Select two or more vitals of the same type and see them compared with the percentage change spelled out in plain language ("down 6.7% since March 1").
 Doctor-Ready Timeline Export	Pick a date range and export a clean PDF summary of every report and metric in that window — meant to be handed to a new doctor at a first consultation.
 Audit Logging	Sensitive actions — account creation, invitations, sharing grants/revokes, card reissues, share views — are written to an immutable, insert-only <code>audit_log</code> table with IP/user-agent capture.
 Full Account Deletion	Typed "DELETE" confirmation, then a properly ordered cascade through every dependent table (respecting the schema's deliberate <code>RESTRICT</code> constraints) — a genuine full erasure, not a soft gesture.

Tech Stack

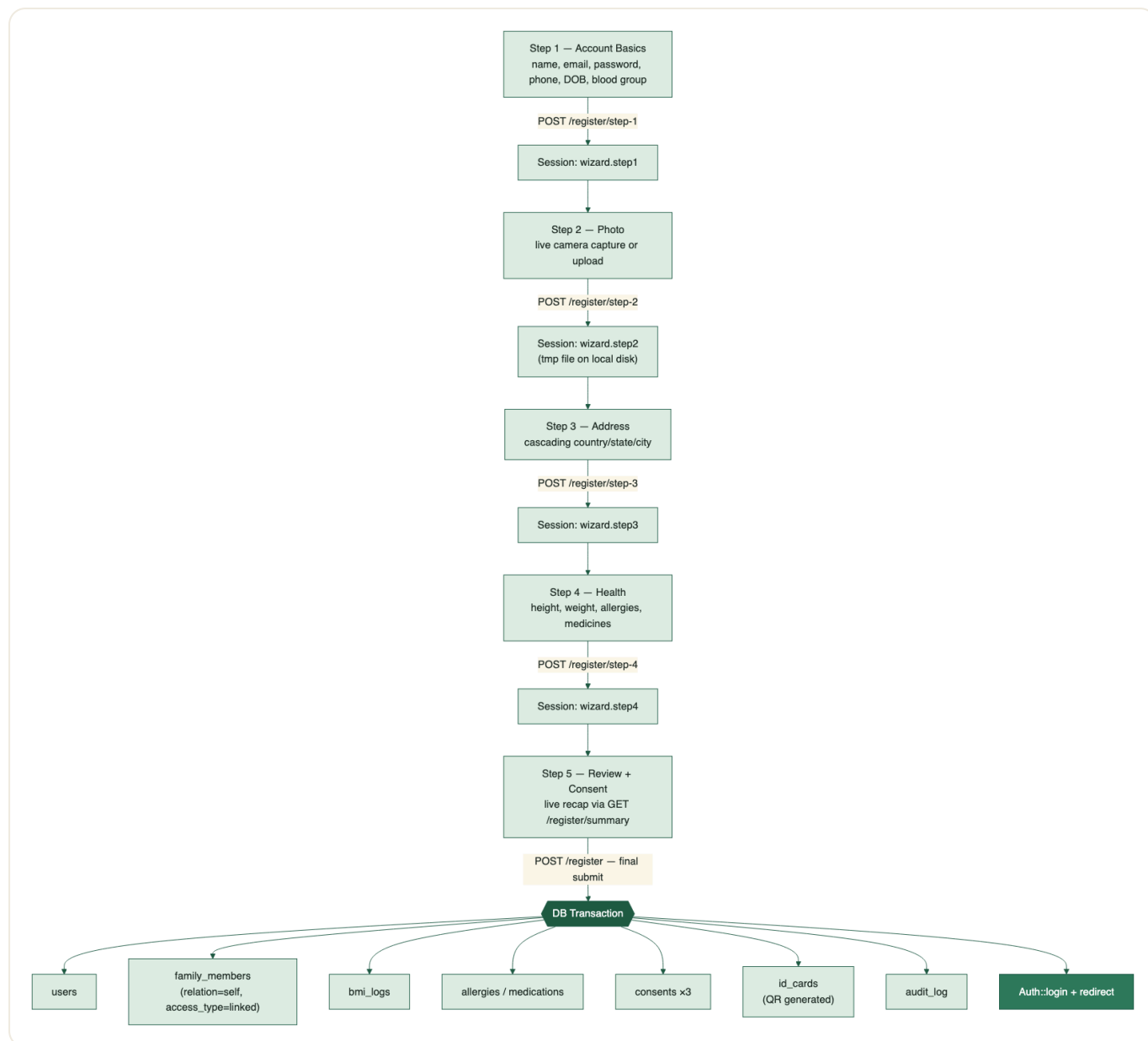
LAYER	TECHNOLOGY	VERSION
Language	PHP	8.2+ (running 8.4.23)
Backend Framework	Laravel	11.54

LAYER	TECHNOLOGY	VERSION
Database	MySQL	8 / 9
Queue	Laravel Queues, <code>database</code> driver	—
Auth Scaffolding	Laravel Breeze (Blade stack)	2.4
OAuth	Laravel Socialite (Google)	5.28
OCR Engine	Tesseract, run as concurrent OS processes per page (via <code>Illuminate\Support\Facades\Process</code>)	5.5
PDF Rasterization	Imagick (PHP ext) + Ghostscript	10.07
AI Providers	Google Gemini REST API (<code>gemini-flash-latest</code> , up to 3 keys) + Groq (OpenAI-compatible chat completions, <code>llama-3.3-70b-versatile</code>) as a fallback — thin custom clients, no heavyweight SDKs	—
Outbound Email	Resend (native Laravel mail transport)	—
PDF Generation	barryvdh/laravel-dompdf	3.1
QR Codes	simplesoftwareio/simple-qrcode (SVG on-screen, PNG embedded in PDFs)	4.2
Templating	Blade components	—
Interactivity	Alpine.js	3.15
CSS Framework	Tailwind CSS + <code>@tailwindcss/forms</code>	3.x
Build Tool	Vite + laravel-vite-plugin	6.x
Location Data	<code>country-state-city</code> (lazy-loaded chunk)	3.2
Fonts	Figtree (via Bunny Fonts, GDPR-friendly)	—
Local Dev	Laravel Herd / <code>php artisan serve</code> + DBngin	—

Why this stack: Laravel's model-level validation (a custom `HasValidation` trait run on every `saving` event) means invalid data can never reach the database even if a caller bypasses form-request validation. Every PDF and QR code in the app is produced by two shared, reusable services — `PdfExportService` and `QrCodeService` — rather than each feature rolling its own, so a wallet card, a full emergency PDF, and a shared-report PDF all go through the exact same, verified rendering path. AI calls are cost-gated by design: only a short, automatic summary is ever generated without the user asking, everything else (detailed explanations, translations, the assistant) is on-demand and cached where it makes sense so re-viewing something already generated never spends usage twice. A single `AIClient` service fronts every AI call and transparently retries across every configured credential — Gemini keys first, Groq last — so no individual feature has to know or care which provider actually served a given request.

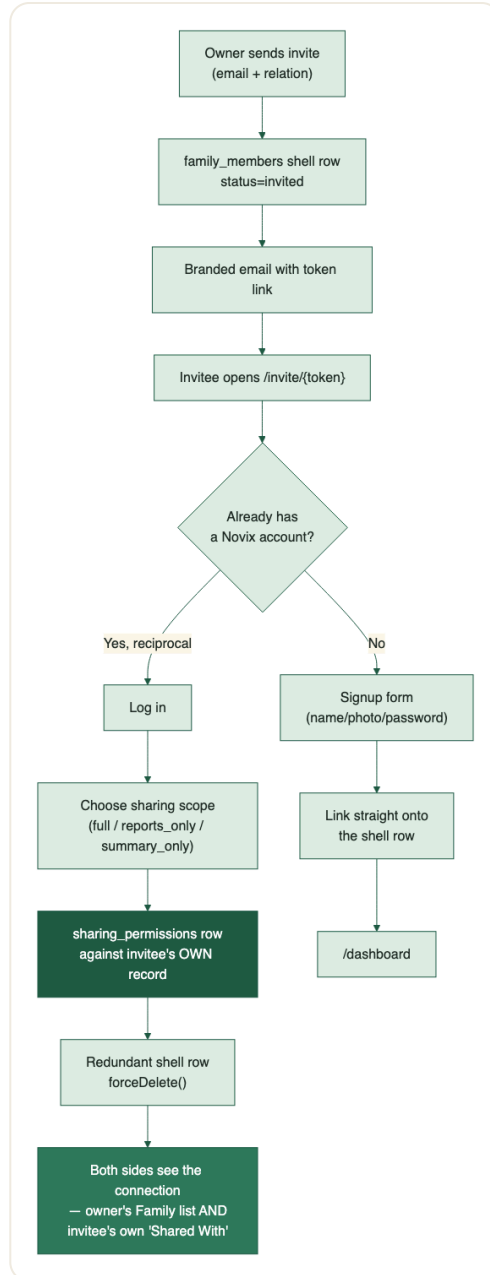
Registration wizard pipeline

The wizard is **session-backed, not client-state-only**: each step's data is validated and persisted to the server session the moment "Next" is clicked (via `fetch`, no page reload), so refreshing mid-signup resumes exactly where you left off. **Nothing touches the database until step 5 commits** — an abandoned signup never leaves a half-created account.



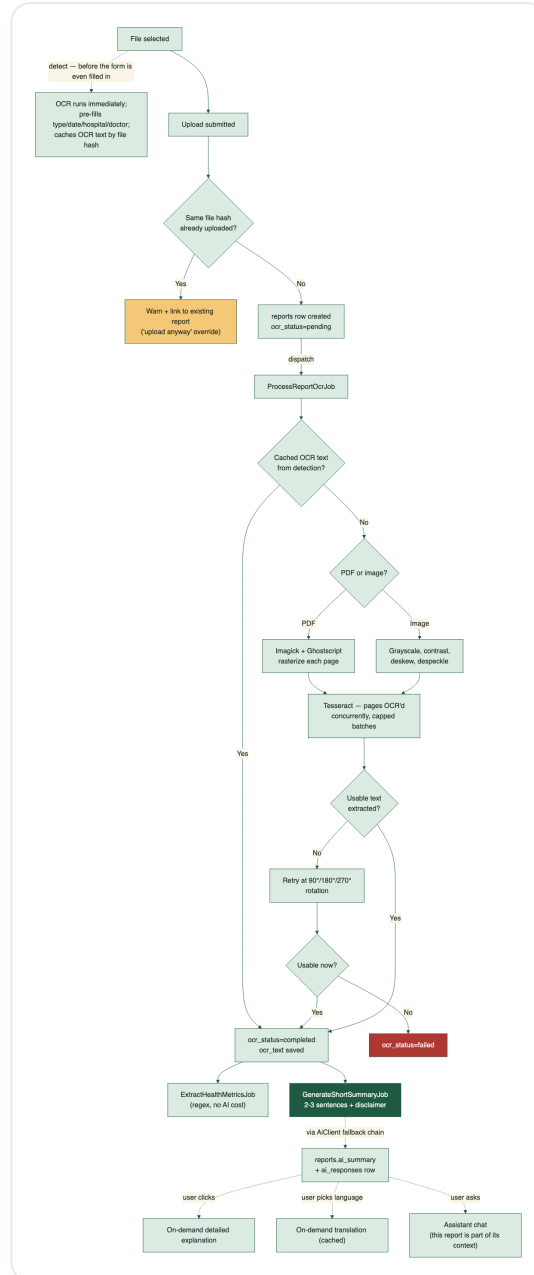
Family invitation & reciprocal sharing pipeline

Inviting someone who **already has their own account** can't simply link them to a second `family_members` row (`linked_user_id` is unique) — so acceptance detects that case and grants a `sharing_permissions` row against their *real* profile instead, leaving both people's own records untouched.



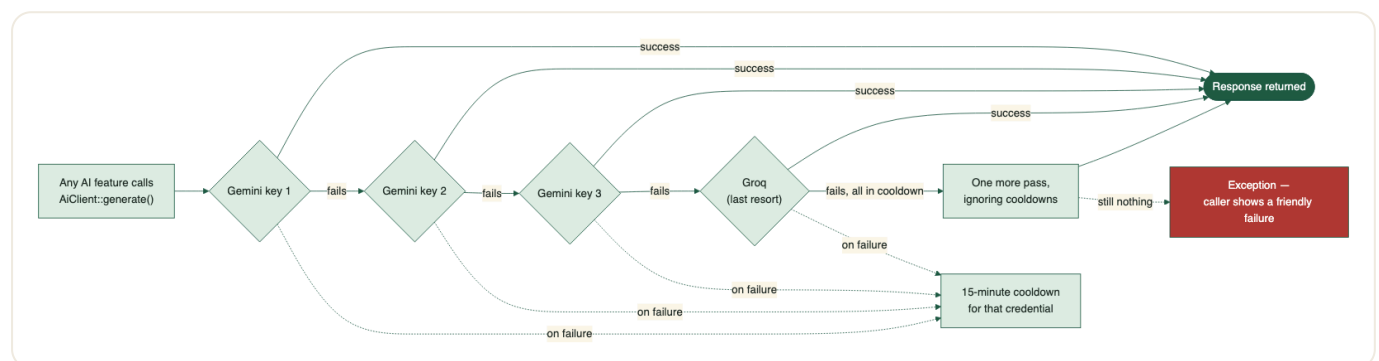
Reports, OCR & AI pipeline

Upload responds **immediately** — OCR and every AI call happen in queued background jobs, never blocking the request. Only the short summary runs automatically; the detailed explanation, translations, and assistant chat are strictly user-initiated. Detection (the moment a file is picked) and the real upload (moments later) share one cached OCR result instead of paying for Tesseract twice.



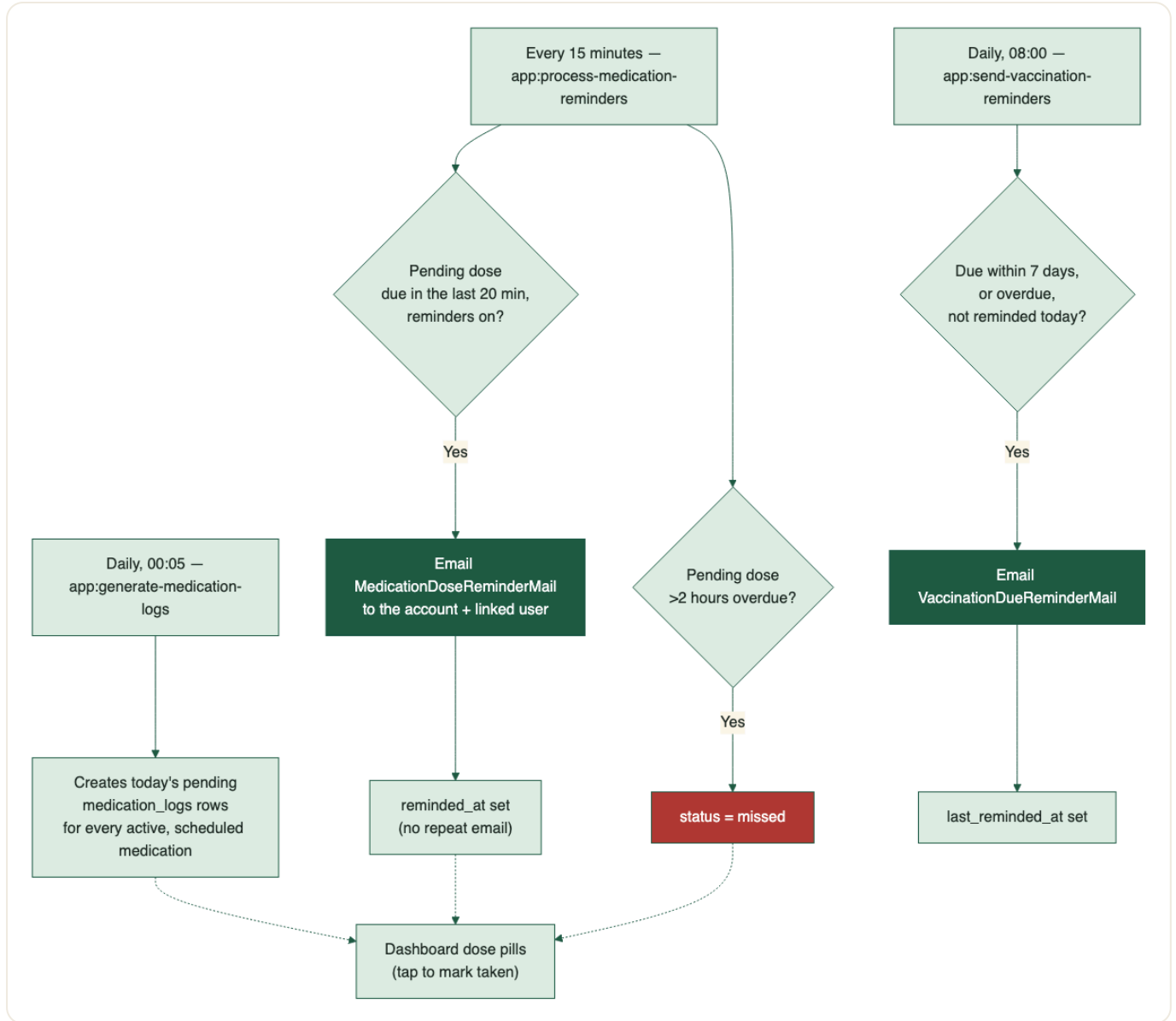
AI provider fallback chain

Every AI feature — report summaries, detailed explanations, translations, the assistant — calls through one **AIClient** service rather than a specific provider directly, so no feature needs to know which credential actually served it.



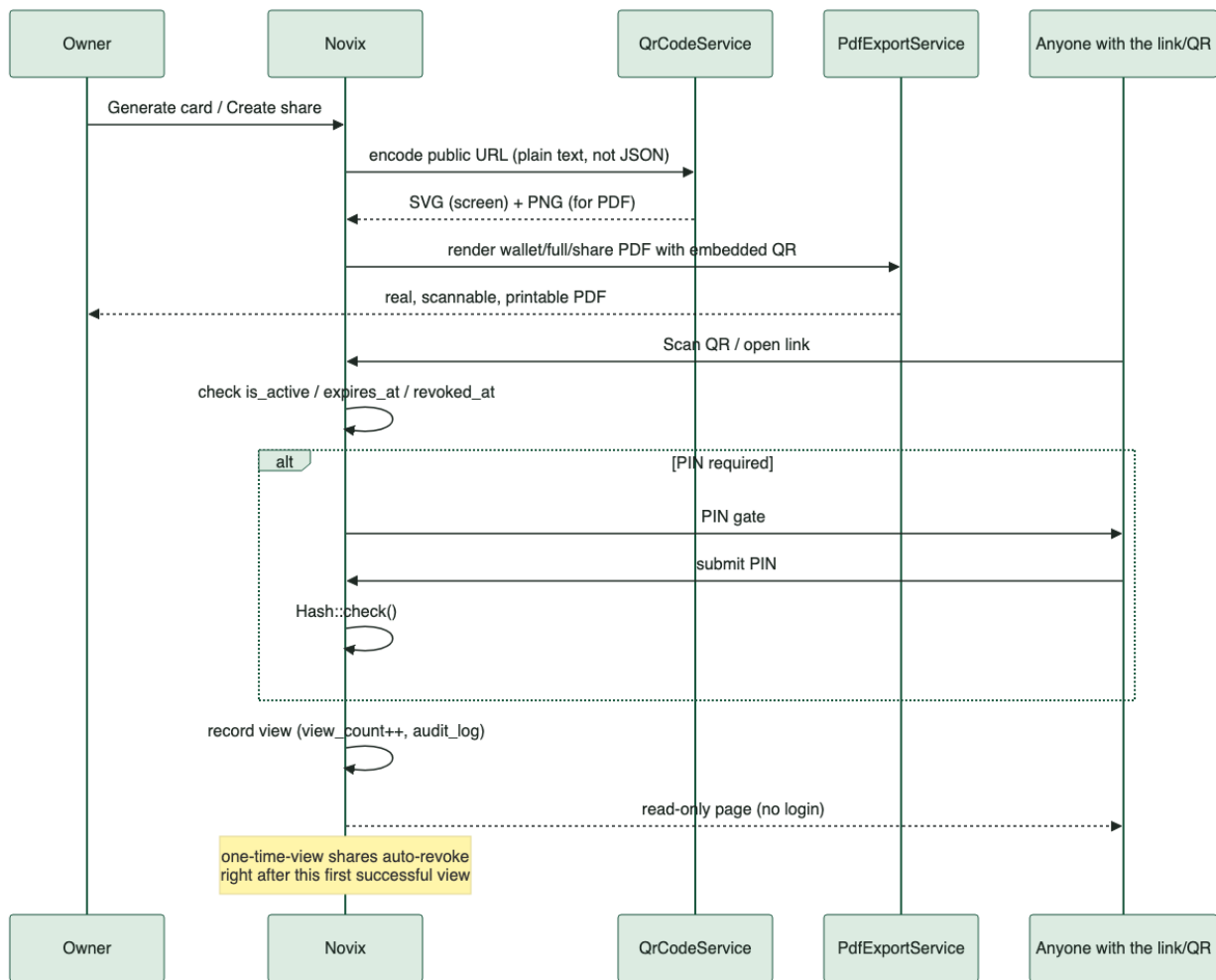
Medication & vaccination reminder pipeline

Two scheduled commands do the actual reminding; a third keeps the dashboard's dose pills backed by real data instead of nothing.



Emergency Card & Report Sharing pipeline

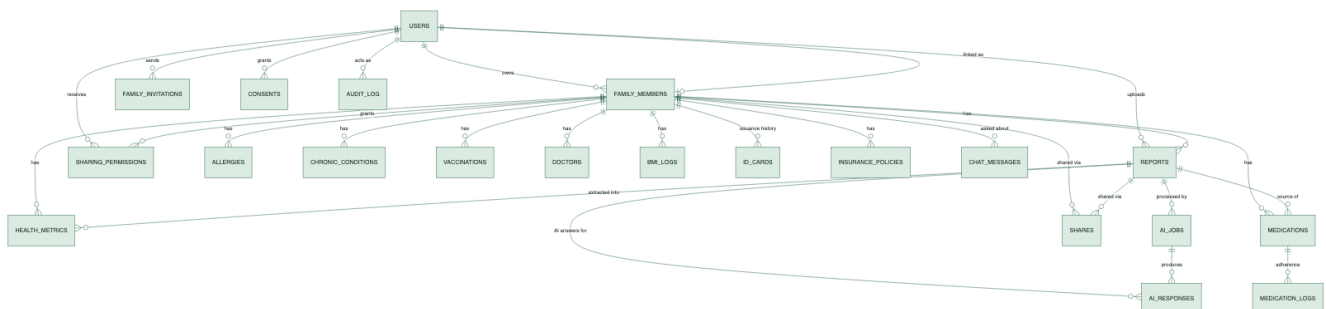
Both features are built on the same two shared services — `QrCodeService` and `PdfExportService` — so a QR code and a PDF are never re-implemented per feature.



Database Schema

29 tables total — 21 domain tables + 8 Laravel framework tables (`users` base columns, `cache` , `jobs` , `sessions` , `password_reset_tokens` , `failed_jobs` , `job_batches` , `migrations`). All domain tables use `utf8mb4_unicode_ci` + InnoDB, with foreign keys carrying deliberate, medically-safe `CASCADE` / `RESTRICT` / `SET NULL` rules — for example, `bmi_logs` , `allergies` , and `medications` all `RESTRICT` deletion of their `family_members` row, so routine record edits can never silently destroy medical history (a full account deletion explicitly cascades through these in the correct order instead).

 **Entity-Relationship Diagram (click to expand)**



1 Identity & Family Structure

The account graph — a Google/password user, the family members they manage, and the email-invitation flow that upgrades a dependent into an independently-logged-in linked member (or reciprocally links two existing accounts).

TABLE	PURPOSE	KEY COLUMNS
 <code>users</code>	Login accounts	<code>email</code> (unique), <code>google_id</code> (unique), <code>password</code> , <code>phone</code> , <code>avatar_path</code> , <code>theme_preference</code> , two-factor columns
 <code>family_members</code>	Every person tracked — self, spouse, kids, parents	<code>primary_account_id</code> → users, <code>linked_user_id</code> → users (nullable, unique), <code>unique_health_id</code> (unique, NVX-XXXXXXX), <code>relation</code> , <code>access_type</code> (<code>linked</code> / <code>dependent</code>), <code>status</code> , DOB, blood group, height/weight, address, emergency contact — soft-deletes
 <code>family_invitations</code>	Email-based invite flow — upgrades a dependent to linked, or reciprocally connects two existing accounts	<code>token</code> (unique), <code>status</code> (<code>pending</code> / <code>accepted</code> / <code>expired</code>), <code>expires_at</code> , <code>invited_by</code>

2 Health Profile

Longitudinal clinical facts not tied to a single report.

TABLE	PURPOSE	KEY COLUMNS
 <code>allergies</code>	Known allergies	<code>allergen_name</code> , <code>severity</code> (<code>mild</code> / <code>moderate</code> / <code>severe</code>), <code>reaction_description</code>
 <code>chronic_conditions</code>	Ongoing conditions	<code>condition_name</code> , <code>status</code> (<code>active</code> / <code>managed</code> / <code>resolved</code>)
 <code>vaccinations</code>	Immunization history	<code>vaccine_name</code> , <code>dose_number</code> , <code>date_administered</code> , <code>next_due_date</code> , <code>last_reminded_at</code> (dedupes the daily reminder email)
 <code>doctors</code>	Known doctors	<code>name</code> , <code>specialization</code> , <code>hospital_or_clinic_name</code>

3 Reports, Vitals & AI Processing

Uploaded documents (full-text searchable), structured vitals, and the async AI summarization pipeline with a full answer-history table — never just the latest response.

TABLE	PURPOSE	KEY COLUMNS
 <code>reports</code>	Uploaded documents	<code>type</code> (<code>blood_test</code> / <code>prescription</code> / <code>xray</code> / <code>mri_ct</code> / <code>insurance</code> / <code>bill</code> / <code>ecg</code> / <code>other</code>), <code>ocr_text</code> (FULLTEXT indexed with <code>ai_summary</code>), <code>ocr_status</code> (<code>pending</code> / <code>processing</code> / <code>completed</code> / <code>failed</code>), <code>ai_summary</code> (cache of the latest short summary), <code>is_archived</code> — soft-deletes

TABLE	PURPOSE	KEY COLUMNS
 <code>bmi_logs</code>	BMI history over time	<code>height_cm</code> , <code>weight_kg</code> , <code>bmi_value</code> (auto-computed), <code>bmi_category</code> (auto-computed), <code>recorded_date</code> , <code>source</code> (<code>manual</code> / <code>report_extracted</code>)
 <code>health_metrics</code>	Extracted vitals (BP, sugar, cholesterol, HbA1c, hemoglobin...)	<code>metric_type</code> , <code>value</code> , <code>unit</code> , <code>recorded_date</code> , <code>source</code> (<code>manual</code> / <code>ocr_extracted</code> / <code>ai_extracted</code>)
 <code>ai_jobs</code>	Async AI job history	<code>job_type</code> (ocr/summary/translation/entity_extraction), <code>status</code> , <code>provider</code> (<code>gemini</code> / <code>groq</code> — whichever actually served the call), <code>input_tokens</code> , <code>output_tokens</code>
 <code>ai_responses</code>	Permanent history of every AI answer — every summary, every detailed explanation, every translation	<code>response_type</code> , <code>content</code> , <code>language</code> , <code>provider</code> , <code>generated_at</code>
 <code>chat_messages</code>	Assistant chat log, per family member	<code>role</code> (<code>user</code> / <code>assistant</code>), <code>content</code> , <code>asked_by_user_id</code> , <code>input_tokens</code> / <code>output_tokens</code> (null for non-AI system replies, so a rate-limit notice never counts against usage)

4 Medications

TABLE	PURPOSE	KEY COLUMNS
 <code>medications</code>	Active/past prescriptions	<code>medicine_name</code> , <code>dosage</code> , <code>frequency</code> , <code>schedule_times</code> (JSON array of <code>HH:MM</code>), <code>active</code> , <code>reminder_enabled</code>
 <code>medication_logs</code>	Per-dose adherence log	<code>scheduled_at</code> , <code>taken_at</code> , <code>reminded_at</code> (dedupes the reminder email), <code>status</code> (<code>pending</code> / <code>taken</code> / <code>missed</code> / <code>skipped</code>)

5 Sharing, Identity Cards & Compliance

TABLE	PURPOSE	KEY COLUMNS
 <code>shares</code>	Time-boxed external share links — never issued without an expiry	<code>token</code> (unique), <code>access_type</code> (single_report/full_summary/emergency_card), <code>shared_with_label</code> , <code>pin_hash</code> (nullable, never the plain PIN), <code>is_one_time</code> , <code>expires_at</code> , <code>revoked_at</code> , <code>first_viewed_at</code> , <code>view_count</code>
 <code>id_cards</code>	Emergency ID cards — full issuance history preserved , never overwritten	<code>card_number</code> (unique), <code>photo_path</code> (snapshot at issue time), <code>qr_code_path</code> , <code>is_active</code>
 <code>consents</code>	Legal/compliance consent capture	<code>consent_type</code> (upload/ai_processing/sharing/account_creation), <code>ip_address</code> , <code>user_agent</code>
 <code>audit_log</code>	Immutable , insert-only action trail	<code>action</code> , <code>target_type</code> , <code>target_id</code> , <code>ip_address</code> — no <code>updated_at</code> by design

TABLE	PURPOSE	KEY COLUMNS
 <code>sharing_permissions</code>	A linked member's explicit, revocable grant of view access	Composite unique (<code>family_member_id</code> , <code>granted_to_user_id</code>), <code>scope</code> , <code>revoked_at</code>
 <code>insurance_policies</code>	Insurance policy tracking	<code>provider_name</code> , <code>policy_number</code> , <code>coverage_amount</code> , <code>expiry_date</code>

```
novix/
├── app/
│   ├── Console/Commands/
│   │   ├── GenerateMedicationLogs.php      # Daily – today's pending dose rows
│   │   ├── ProcessMedicationReminders.php  # Every 15 min – reminder emails + missed sweep
│   │   ├── SendVaccinationReminders.php    # Daily – due-soon/overdue reminder emails
│   │   └── ExpireFamilyInvitations.php
│   ├── Http/Controllers/
│   │   ├── Auth/                          # Login, Google OAuth, registration wizard
│   │   ├── Concerns/                      # ResolvesActiveFamilyMember (shared trait)
│   │   ├── DashboardController.php
│   │   ├── EmergencyCardController.php    # Public emergency card + PDFs
│   │   ├── FamilyController.php           # Family list, show, archive/restore
│   │   ├── FamilyAddController.php        # /family/add form
│   │   ├── FamilyInviteController.php     # Invite by email
│   │   ├── FamilyDependentController.php  # Add a dependent
│   │   ├── InvitationController.php       # Accept/decline flow (public + reciprocal)
│   │   ├── IdCardController.php           # Owner-side card management
│   │   ├── ReportUploadController.php     # Batch upload + upload-time auto-detect
│   │   ├── ReportController.php           # Report detail, search/filter, OCR text edit
│   │   ├── ReportAiController.php         # Detailed explanation, translation, retry
│   │   ├── MedicationController.php       # CRUD + dashboard dose-toggle
│   │   ├── VaccinationController.php      # CRUD
│   │   ├── AiChatController.php           # Assistant chat
│   │   ├── ShareController.php            # Owner-side share creation + history
│   │   ├── PublicShareController.php      # Public share view, PIN gate, PDF
│   │   ├── TimelineController.php         # Merged timeline + PDF export
│   │   └── ProfileController.php
│   ├── Http/Requests/Registration/        # Per-step wizard validation
│   ├── Jobs/                              # ProcessReportOcrJob, ExtractHealthMetricsJob,
│   │                                       # GenerateShortSummaryJob
│   ├── Mail/                              # FamilyInvitationMail, MedicationDoseReminderMail,
│   │                                       # VaccinationDueReminderMail
│   ├── Rules/                             # NoHeaderInjection (CRLF-injection hardening)
│   ├── Services/
│   │   ├── Ai/                            # AiClient – multi-credential fallback router
│   │   ├── Assistant/                     # AssistantContextBuilder (prompt from real records)
│   │   ├── Gemini/                       # GeminiClient
│   │   ├── Groq/                         # GroqClient
│   │   ├── Ocr/                          # OcrExtractor (Tesseract + Imagick, parallel pages)
│   │   ├── Pdf/                          # PdfExportService (shared by every PDF)
│   │   ├── Qr/                           # QrCodeService (shared by every QR code)
│   │   └── Reports/                      # HealthMetricExtractor, ReportFieldDetector
│   ├── Models/
│   │   ├── Concerns/HasValidation.php     # Model-level validation trait
│   │   └── *.php                         # 21 domain models
│   └── Policies/
├── config/emergency_card.php              # Static EN/HI/GU label dictionary
├── database/migrations/                   # 34 sequential migrations
├── resources/
│   ├── js/
│   │   ├── alpine/                      # registration-wizard, camera-capture, bmi-gauge,
│   │   │                                       # location-select, tag-input, report-upload,
│   │   │                                       # report-processing, metric-compare, share-actions,
│   │   │                                       # assistant-chat, dose-tracker...
│   │   └── app.js                        # Registers all Alpine.data components
└── views/
```

```

├── auth/wizard/           # 5 step partials
├── components/           # Reusable x-* Blade components
├── emergency/            # Public card + PDF templates
├── emails/               # Branded HTML email templates
├── family/               # Family list/show/add
├── invite/               # Public invitation accept flow
├── medications/          # List, create/edit form
├── vaccinations/         # List, create/edit form
├── assistant/            # Chat UI
├── profile/tabs/         # Profile tabs (reused for dependents & full-access)
├── reports/              # Upload, index, detail
├── shares/               # Owner create/history + public views
├── timeline/             # Merged timeline + PDF export
├── dashboard.blade.php
└── routes/
    ├── web.php
    ├── console.php       # Scheduled command registration
    └── auth.php

```

Application Routes

100+ routes — click to expand full list, grouped by feature

Auth & Registration

METHOD	URI	NAME
GET/POST	<code>/register</code> , <code>/register/step-{1..4}</code>	<code>register.*</code>
GET	<code>/register/check-email</code> , <code>/register/photo-preview</code> , <code>/register/summary</code>	<code>register.*</code>
GET/POST	<code>/login</code> , <code>/logout</code>	<code>login</code> , <code>logout</code>
GET/POST	<code>/auth/google/redirect</code> , <code>/auth/google/callback</code>	<code>auth.google.*</code>
GET/POST	<code>/forgot-password</code> , <code>/reset-password</code>	<code>password.*</code>

Dashboard & Profile

METHOD	URI	NAME
GET	<code>/dashboard</code>	<code>dashboard</code>
POST	<code>/dashboard/switch/{familyMember}</code> , <code>/dashboard/dismiss-onboarding</code>	<code>dashboard.*</code>
GET	<code>/profile</code>	<code>profile.edit</code>
POST	<code>/profile/{familyMember?}/{basic-info,photo,address,health,emergency-contact}</code>	<code>profile.*</code>

METHOD	URI	NAME
PATCH	/profile/theme	profile.theme
DELETE	/profile	profile.destroy

Family Management

METHOD	URI	NAME
GET	/family, /family/add, /family/{familyMember}, /family/{familyMember}/edit	family.*
POST	/family/invite, /family/dependent	family.invite.store, family.dependent.store
POST/DELETE	/family/invite/{invitation}/{resend,cancel}	family.invite.*
POST	/family/{familyMember}/{archive,restore}	family.*
POST	/family/sharing/{sharingPermission}/revoke	family.sharing.revoke
GET/POST	/invite/{token}, /invite/{token}/{register,permission,dismiss}	invite.*

Reports, OCR & AI

METHOD	URI	NAME
POST	/reports/detect	reports.detect (upload-time auto-detect)
GET/POST	/reports/upload, /reports	reports.upload, reports.store, reports.index (search + type/date filters)
GET	/reports/{report}, /reports/{report}/{status,file}	reports.show, reports.status, reports.file
PATCH	/reports/{report}/ocr-text	reports.ocr-text
POST	/reports/{report}/{detailed-explanation,translate,retry-summary}	reports.*

Medications & Vaccinations

METHOD	URI	NAME
GET	/medications, /medications/create, /medications/{medication}/edit	medications.*
POST/PATCH/DELETE	/medications, /medications/{medication}	medications.*
POST	/medications/{medication}/toggle-dose	medications.toggle-dose
GET	/vaccinations, /vaccinations/create, /vaccinations/{vaccination}/edit	vaccinations.*

METHOD	URI	NAME
POST/PATCH/DELETE	<code>/vaccinations</code> , <code>/vaccinations/{vaccination}</code>	<code>vaccinations.*</code>

AI Assistant

METHOD	URI	NAME
GET	<code>/assistant</code>	<code>assistant</code>
POST	<code>/assistant/send</code>	<code>assistant.send</code>

Emergency Card

METHOD	URI	NAME
GET	<code>/emergency/{cardNumber}</code> , <code>/emergency/{cardNumber}/pdf</code> , <code>/emergency/{cardNumber}/pdf/wallet</code>	<code>emergency.*</code> (public, no auth)
GET	<code>/id-card</code>	<code>id-card.show</code>
POST	<code>/id-card/reissue</code> , <code>/id-card/{idCard}/toggle-active</code>	<code>id-card.*</code>

Report Sharing

METHOD	URI	NAME
GET/POST	<code>/shares/create</code> , <code>/shares</code> , <code>/shares/history</code>	<code>shares.*</code>
POST	<code>/shares/{share}/revoke</code>	<code>shares.revoke</code>
GET/POST	<code>/s/{token}</code> , <code>/s/{token}/pin</code> , <code>/s/{token}/pdf</code> , <code>/s/{token}/file/{report}</code>	<code>share.public.*</code> (public, no auth)

Health Timeline

METHOD	URI	NAME
GET	<code>/timeline</code> , <code>/timeline/export</code>	<code>timeline</code> , <code>timeline.export</code>

Getting Started

Prerequisites

- PHP 8.2+ with Composer
- MySQL 8/9 (via [DBngin](#), Laravel Herd, or any local install)
- Node.js + npm
- **Tesseract OCR** and **Ghostscript** (`brew install tesseract ghostscript` on macOS) — required for the report OCR pipeline

- The PHP **Imagick** extension — required for PDF rasterization and PNG QR generation
- A [Google Gemini API key](#) — required for AI summaries/explanations/translations/assistant chat. Up to 2 backup Gemini keys and a [Groq API key](#) are optional — if set, AI features automatically fall back through them in order when one hits its free-tier limit or fails (see `App\Services\Ai\AiClient`)
- A [Google OAuth client ID/secret](#) (optional, for Google sign-in)

Installation

```
git clone https://github.com/neevmodh/Novix.git
cd Novix

# Install dependencies
composer install
npm install

# Configure environment
cp .env.example .env
php artisan key:generate

# Point .env at your database, then:
php artisan migrate
php artisan storage:link

# Build front-end assets
npm run build
```

Add your credentials to `.env`:

```
GOOGLE_CLIENT_ID=your-google-oauth-client-id
GOOGLE_CLIENT_SECRET=your-google-oauth-client-secret
GOOGLE_REDIRECT_URI=http://localhost:8000/auth/google/callback

GEMINI_API_KEY=your-gemini-api-key
GEMINI_API_KEY_2=optional-backup-gemini-key
GEMINI_API_KEY_3=optional-backup-gemini-key
GEMINI_MODEL=gemini-flash-latest
GROQ_API_KEY=optional-groq-key-as-final-fallback
GROQ_MODEL=llama-3.3-70b-versatile

# Family invitations and medication/vaccination reminders need a real
# mailer — defaults to MAIL_MAILER=log (writes to the log file, sends
# nothing) until you set this up. Uses Resend (resend.com, free tier)
# by default; swap MAIL_MAILER and its config in config/mail.php for
# SMTP/Postmark/SES if you'd rather use something else.
MAIL_MAILER=resend
MAIL_FROM_ADDRESS="onboarding@resend.dev"
RESEND_KEY=your-resend-api-key

QUEUE_CONNECTION=database
```

Note: Resend's `onboarding@resend.dev` sender only delivers to the email address your Resend account was created with, until you verify a custom domain (resend.com/domains) — needed before invitations can reach anyone besides yourself.

Important: `php artisan serve` and `queue:work` only read `.env` once, at startup. If you change any credentials while they're already running, restart both — otherwise they'll keep using the old values silently.

Run the app **and** a queue worker — OCR and AI calls run as background jobs and never block the upload response:

```
php artisan serve
php artisan queue:work
```

Then visit <http://localhost:8000> 🎉

Security & Privacy

- Model-level validation (`HasValidation` trait) runs on every `saving` event — invalid data can never reach the database even if a caller bypasses form-request validation.
- Every route touching family data verifies record ownership or an active `sharing_permissions` grant against the logged-in user; edit-level actions require full-scope access, never just a viewing grant.
- Foreign keys use deliberate, medically-safe cascade rules — `RESTRICT` on tables that hold real medical history (`bmi_logs` , `allergies` , `medications` , `reports` ...), so routine edits can never silently wipe it.
- A brand-new Google identity is never written to `users` until registration fully completes — no half-created accounts from an abandoned signup, via either auth path.
- **Share links always expire** — there is no "never expires" option, by design. A 4-digit PIN is stored as a hash, never in plain text. A one-time-view link auto-revokes itself immediately after its first successful view; an owner's manual revoke is always an absolute, immediate stop for everyone, including whoever was mid-view.
- **Public pages leak nothing extra.** The emergency card shows only what a responder needs (never the home address); a shared report's PDF shows only name/age/blood group (never address or emergency contact) alongside the actual report content.
- Report files and QR codes are stored on a private disk and served through authorization-checked routes — never a public, guessable URL.
- Sensitive actions — account creation, invitations, sharing grants/revokes, card reissues/deactivation, and every share view — are written to an append-only `audit_log` with IP/user-agent capture.
- AI cost is bounded by design: only the automatic short summary ever runs without a user click, and every other AI feature is on-demand and cached where re-viewing the same thing shouldn't spend usage twice.
- A custom `NoHeaderInjection` validation rule rejects embedded CR/LF in every user-supplied email field that reaches outbound mail (family invitations, password reset, registration) — closes a real CRLF-injection gap in Laravel's own default `email` validation rule (CVE-2026-48019) that's unpatched on this app's framework line.
- Full account deletion requires a typed "DELETE" confirmation plus current-password re-entry, and explicitly cascades through every dependent table in the correct order.
- 2FA columns (`two_factor_secret` , `two_factor_recovery_codes`) are stored `encrypted` / `encrypted:array` at the Eloquent cast level.

Found a vulnerability? Please open a private security advisory rather than a public issue.



Roadmap

- ☒ Full database schema (29 tables, normalized, FK-audited)
 - ☒ Session-backed multi-step registration wizard
 - ☒ Google OAuth + email/password auth
 - ☒ Family dashboard with live BMI gauge and a first-run checklist
 - ☒ Tabbed profile editor
 - ☒ Family invitations — dependents and reciprocal linked-account sharing
 - ☒ Emergency ID card with real QR generation, reissue, and instant deactivate
 - ☒ Dark mode (server-persisted)
 - ☒ Report upload with upload-time auto-detect and duplicate detection
 - ☒ Fast, parallel OCR pipeline (Tesseract + Imagick/Ghostscript) with rotation retry
 - ☒ AI report summarization, on-demand detailed explanations, cached translation, and an assistant chat
 - ☒ Multi-credential AI fallback chain (3 Gemini keys + Groq) — no single key outage takes AI features down
 - ☒ Medication management with reminder scheduling and real email delivery (Resend)
 - ☒ Vaccination tracking with due/overdue reminder emails
 - ☒ Health timeline with filters, full-text search, and compare-over-time
 - ☒ Secure, time-boxed, PIN-protectable report sharing links with real QR + PDF export
 - ☐ Insurance policy management UI (`insurance_policies` table exists — no controller/views yet)
 - ☐ Domain verification for outbound email (currently limited to the Resend account's own address until a custom domain is verified)
 - ☐ Public deployment
 - ☐ Native mobile app / PWA packaging
-



Contributing

Contributions, issues, and feature requests are welcome!

1. Fork the repo
 2. Create your feature branch (`git checkout -b feature/amazing-feature`)
 3. Commit your changes (`git commit -m 'Add some amazing feature'`)
 4. Push to the branch (`git push origin feature/amazing-feature`)
 5. Open a Pull Request
-



License

Distributed under the **Apache License 2.0**. See `LICENSE` for details.
